

Technical & organisational measures (TOMs)

GDPR Art. 32. Annex 2 to the DPA. **Honest** — gaps are listed with remediation, because a procurement team trusts a named gap + a plan more than a glossy claim.

Draft for review. See README.md .

In place

Encryption

- In transit: HTTPS/TLS on every hop (browser↔Vercel, Vercel↔Turso, Vercel↔Anthropic).
- At rest: Turso volume-level encryption (+ optional page-level AES/AEGIS-256, keys in memory only); Vercel AES-256.

Data residency

- Database at rest: EU — Ireland (aws-eu-west-1).
- App compute: EU — Frankfurt (fra1), pinned in vercel.json .

Access control

- Facilitator area (dashboards, research, AI endpoints) behind HTTP basic auth.
- Client pages reachable only via an unguessable per-sprint token (no listing, not indexed — robots: noindex).
- Production secrets in environment variables (Vercel/ .env*), never in code or git; verified no secret is committed.

AI data handling

- Anthropic does not train on the data. Inputs/outputs auto-deleted within 30 days. Data minimised before it reaches the AI (panelists = first name + age; assessment sends numbers).

Data lifecycle

- Working erasure (npm run delete-sprint ... --apply) and backup (npm run backup) capabilities.

Software

- Managed platform (Vercel) — OS/runtime patching handled by the provider. No customer-managed servers.

Gaps & remediation (honest)

Gap	Risk	Remediation	Priority
Shared facilitator password (one basic-auth login for the whole team)	No individual accountability; no record of who accessed what; can't revoke one person	Move to per-user accounts with individual credentials	High — before first real client
No access audit log	Can't show who viewed a sprint's data when	Add request/access logging on facilitator routes	High

Gap	Risk	Remediation	Priority
No MFA on the facilitator login	Weaker against credential compromise	Add MFA with per-user accounts	Medium
Client links are bearer tokens	Anyone with the link can open that sprint's intake	By design (frictionless client access); mitigate with link expiry + per-sprint rotation	Medium
Manual backups	A missed backup before an incident	Schedule <code>npm run backup</code> (cron / Vercel Cron)	Medium
No formal incident-response runbook	Slower, inconsistent breach handling	Write a one-page IR runbook (who, what, the 24/48h notify clock)	Medium
No penetration test	Unknown unknowns	Commission a light pen-test before scaling beyond the pilot	Low→Medium

Organisational

Small team; access on a need-to-know basis. Confidentiality is part of the founders' / contractors' engagement.

Sub-processors are vetted (see `02_subprocessor-list.md`) and bound by their own DPAs.

This pack is the documented baseline; review it each time the architecture changes.